

AI-SOC?

到底AI怎麼用在SOC ?

陳澤森 (Sam) — DevSecOps Taiwan 副社長



Who am I?

- 陳澤森 (Sam Chan) · DevSecOps Taiwan 副社長
- 香港資訊科技學院 (HKIIT) 資安講師
- 曾在美商、日商、台商、新創、上市櫃公司及跨國集團工作，深入理解不同企業文化與資安需求，能為企業提供最適切的安全培訓
- 豐富的技術與管理經驗 — 擔任過 Software Engineering Lead、System Administrator Lead，以及 Global Cybersecurity 主管，融合技術與管理視角，制定企業資安策略
- 資安標準與法規合規經驗 — 熟悉 ISO 27001、GDPR、NIST、CIS 等資安標準，能夠指導企業合規並建立強健的資安治理框架
- DevSecOps 與安全自動化專家 — 熟悉 DevSecOps 流程與工具，能夠將安全融入軟體開發生命週期 (SDLC)，提升企業的安全防護能力



Agenda

今天的路線圖 (保證不無聊)



先複習一首歌

相信我，跟資安有關

01

什麼是 SOC ?

SOC 的定義、MSSP 的日常，以及跟 SIEM 的差別

02

AI 關鍵名詞

先對齊歌詞，才能一起合唱 — Prompt / RAG / HITL

03

為什麼 SOC 需要 AI ?

SOC 分析師的日常、兩套語言怎麼融合、合體之後改變了什麼

04

高階架構：四段合體公式 + 實戰走一遍

每段回答「為什麼要這樣做」，釣魚信案例從告警走到報告，先講清楚哪裡會炸

05

Key Takeaways

最後三句話帶你走

開始之前，先複習一首歌 ♪

2016 年洗腦全世界的那首 — PPAP



→ Uh! 蘋果筆



→ Uh! 鳳梨筆

蘋果筆 + 鳳梨筆

→ Uh! PPAP !

今天要做的事，本質上一模一樣：



AI +



SOC



Uh! AI-SOC !

01

什麼是 SOC ?

先搞懂 *SOC* 在做什麼、跟 *SIEM* 差在哪

什麼是 SOC ?

Security Operations Center 資安維運中心 —— 企業的 24×7 資安中樞

SOC = 集中化的資安團隊與設施：7×24 監控、偵測、分析並應變資安事件

SOC 在 MSSP (Managed Security Service Provider , 資安託管服務商) 裡做什麼？—— 一個 SOC , 服務多家企業

24×7 監控與分診

替多家客戶盯著告警，過濾雜訊、分級處理

事件應變與通報

依 SLA 即時通知客戶，提供處置建議與報告

日誌與 SIEM 代管

集中收容客戶日誌，維運與調校偵測規則

威脅情資與獵捕

跨客戶共享情資，主動獵捕潛伏威脅

那 SIEM 又是什麼？

Security Information and Event Management —— 最常跟 SOC 搞混的一個詞

SIEM = 集中收集日誌、關聯分析、發出告警的「平台」—— 它是工具，不是團隊

SOC 是「部隊」

人與流程的組織
分析師、SOP、7×24 輪班
負責判斷、應變、扛責任

VS

SIEM 是「武器」

平台與工具（系統）
收日誌、跑關聯規則
負責蒐集、偵測、丟告警

SOC「用」SIEM —— 買了武器不等於有部隊：導入 SIEM ≠ 擁有 SOC

02

AI 名詞解釋

先對齊歌詞，才能一起合唱 🎤

AI Glossary (1/2) — 基礎概念

LLM (Large Language Model)

以海量文本訓練的語言模型，擅長理解與生成文字。
關鍵限制：它「不知道你公司的事」。

Prompt Engineering

設計輸入指令的技巧，決定模型輸出的品質、格式與穩定性。同一個模型，不同 prompt，結果天差地遠。

Hallucination (幻覺)

模型「自信地」講出錯誤內容。
在 SOC 場景中是最需要工程手段防範的風險。

RAG (Retrieval-Augmented Generation)

先檢索組織自己的知識，再讓模型根據檢索結果回答 — 把「通用模型」變成「懂你環境的分析師」。

AI Glossary (2/2) — 工程與治理概念

Harness Engineering

不只設計 prompt，而是設計模型運作的整個框架：輸入輸出格式、工具呼叫、驗證與防護欄 (guardrails)。

Embedding / Vector Knowledge Base

把文件轉成向量，讓系統能用「語意」而非「關鍵字」找到相關知識 — RAG 的檢索基礎。

Human-in-the-Loop (HITL)

AI 產出 → 人類審核 → 才執行。
AI 是副駕駛，分析師仍握方向盤。

Feedback Loop

分析師的修正回饋進知識庫，讓系統隨組織一起成長 — 就像那首歌一樣，越循環越洗腦。

03

為什麼 SOC 需要 AI ?

先看痛點，再看合體之後改變了什麼

SOC 分析師的日常 🤪

這些問題一點都不新 — 這正是重點

Alert 疲勞

每天數千條告警，L1 分析師淹沒在誤報裡 — 真正的威脅反而像在玩威利在哪裡。

知識斷層

資深分析師的經驗都在腦中；人一離職，know-how 跟著打包走人。

回應不一致

同一種告警，早班和晚班給出兩種品質的處置 — 全看當下誰值班。

人才缺口

資安人力長期短缺，招募困難、訓練週期長，好不容易養成又被挖走。

AI × SOC：兩套語言，一鍋融合

AI 圈與資安圈各說各話 —— 直到有人把它們揉成一顆新丸子

AI 的世界

模型 Model / 代理 Agent
Token / 提示詞 Prompt
幻覺 Hallucination

+

SOC 的世界

告警 Alert / SIEM
分診 Triage / 威脅獵捕
事件應變 Incident Response

Pen + Apple
PPAP

撒尿蝦 + 牛丸
撒尿牛丸

AI + SOC
AI-SOC

合體之後，改變了什麼？

Four measurable wins

1

回應準確度提升

RAG 讓 AI 根據「你的」SOP 與歷史案例回答，而非通用網路知識，大幅降低幻覺。

2

回應時間縮短

初步 triage 與調查報告從「小時級」縮短到「分鐘級」。

3

有效回應率提升

每一條告警都得到一致品質的分析，不再因疲勞或經驗差異而漏判。

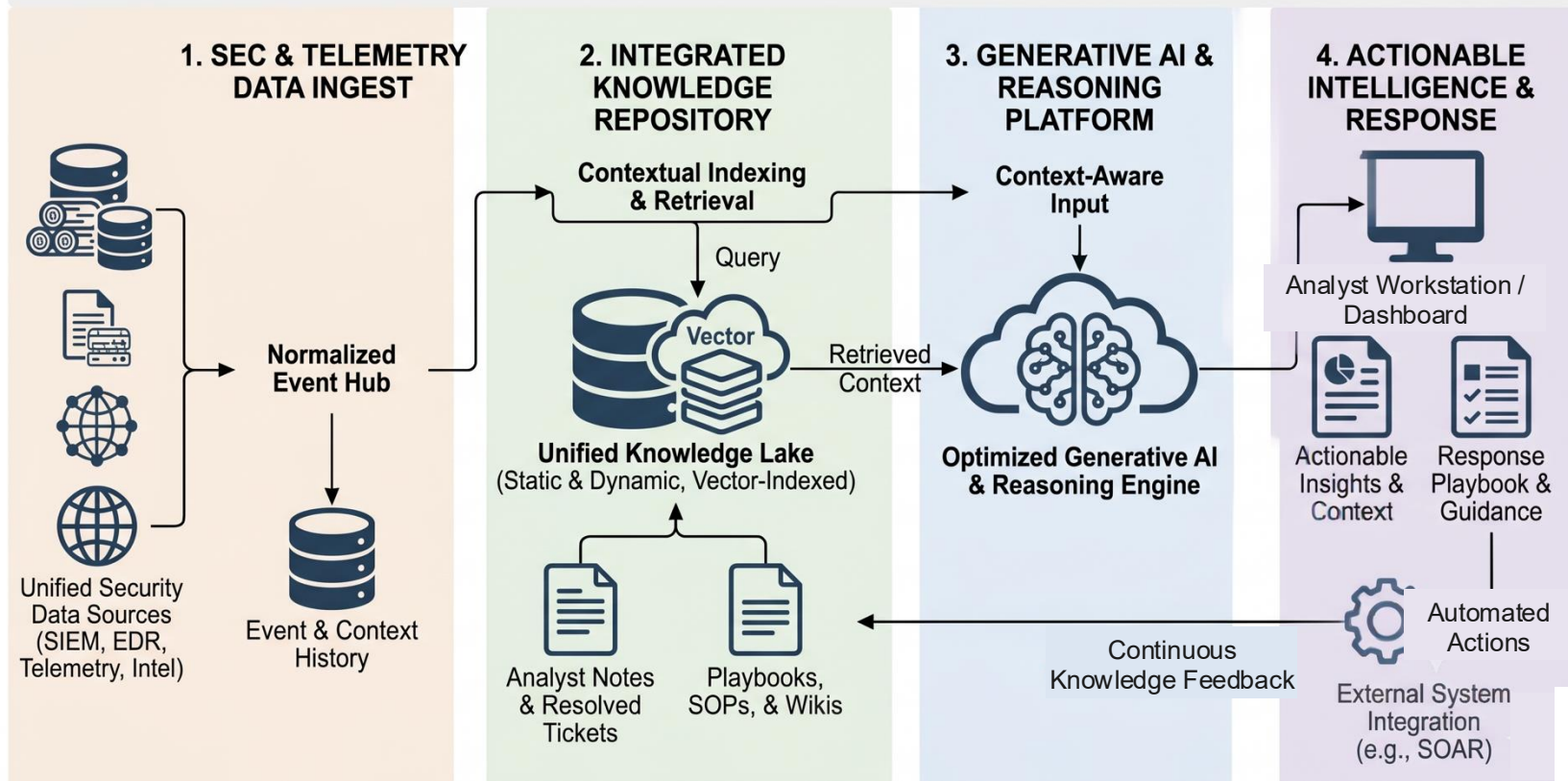
4

人力釋放

L1 重複性工作交給 AI，分析師轉向威脅獵捕與深度調查等高價值任務。

高階架構：四段合體，一個洗腦循環

High-Level Architecture of RAG-Enhanced AI SOC Analyst



1

Ingestion & Normalization

第一次合體 — *the foundation*

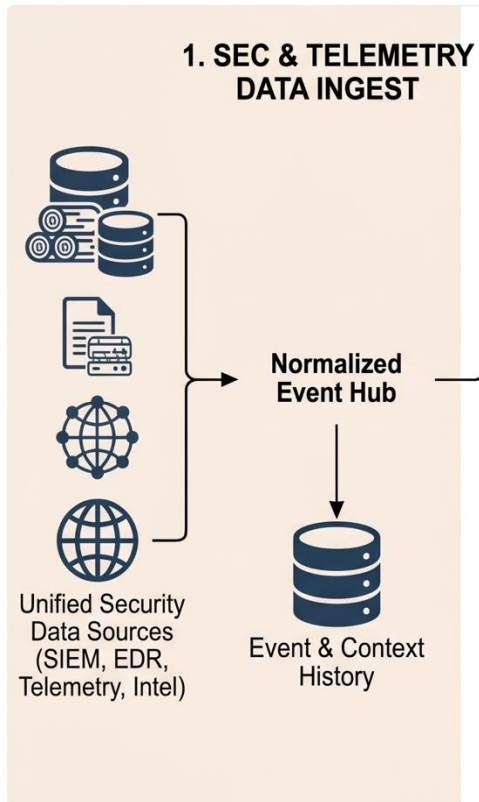
做什麼

SIEM / EDR / Threat Intel 等異質來源 → Normalization Engine (OCSF Schema) → Case Management / Incident DB。

為什麼

每家工具的告警格式都不同；沒有統一的 canonical schema，下游的檢索與 AI 分析就無從談起。採用 OCSF 開放標準，避免被單一 vendor 綁定。

🚨 雜亂告警 + 📄 OCSF → Uh! Normalized Alert !



2

RAG & Knowledge Base

第二次合體 — *make the AI know YOUR environment*

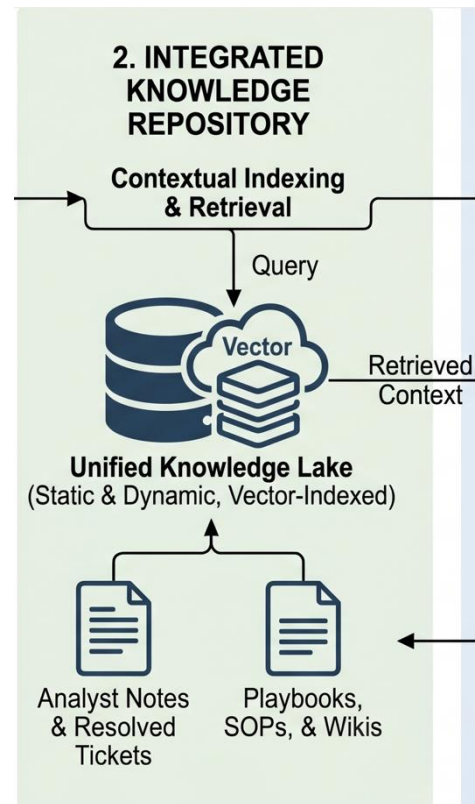
做什麼

把組織知識嵌入 Vector Knowledge Base。來源分兩類：Static (Playbooks、SOPs、Wiki) 與 Dynamic (已結案 tickets、分析師筆記)。

為什麼

通用 LLM 不認識你的網路拓撲、命名慣例、內部流程。RAG 讓模型「查了資料再回答」，而不是憑印象亂猜 — 這是準確度提升的核心機制。

 SOP +  已結案 Ticket → Uh! Knowledge Base !



3

AI Reasoning & Synthesis

第三次合體 — *context in, quality out*

做什麼

Contextual Prompt Assembly 把「正規化告警 + SOP + 歷史解法」組成完整上下文，交給 LLM 產生 context-aware 回應。

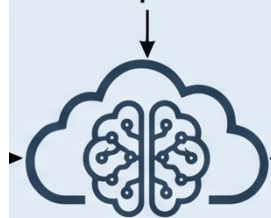
為什麼

Prompt 品質決定輸出品質。結構化的 prompt assembly (而非讓分析師自由發問) 確保每次分析都涵蓋必要面向，輸出格式一致、可稽核。

Normalized Alert + Knowledge Base → Uh! Context-Aware Prompt !

3. GENERATIVE AI & REASONING PLATFORM

Context-Aware Input



Optimized Generative AI & Reasoning Engine

Continuous Knowledge Feedback

4

Delivery & Analyst Action

第四次合體 — *human in the loop*

做什麼

輸出三層 deliverables : Threat Summary、Security Team Action Items、Infrastructure Team Remediation。分析師在 Dashboard 上 Analyze / Edit / Approve。

為什麼

Human-in-the-Loop 確保問責 — AI 建議、人類決策。分析師的修正透過 Feedback Loop 回饋知識庫，系統越用越準。



AI 草稿

+

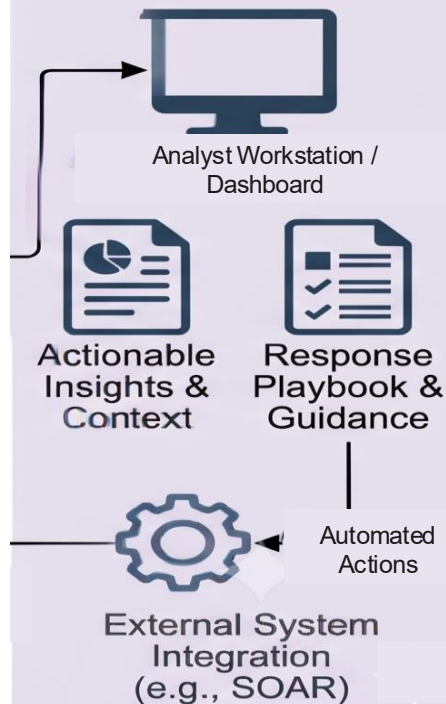


人類拍板

→

Uh! 回饋進 Knowledge Base !

4. ACTIONABLE INTELLIGENCE & RESPONSE



最後，全部合體 🎵



四段合體 + Feedback Loop → Uh! AI-SOC ! 🔄

跟那首歌一樣洗腦 — 每處理一條告警，loop 就自動再轉一圈，系統越轉越聰明。

實戰走一遍 (1/3)：一封釣魚信進來了

Step 1 — 原始告警長這樣 (生資料，人類看了頭痛)

```
{
  "src": "email-gw-03",
  "event_id": "PH-20261012-8841",
  "verdict": "suspicious",
  "sender": "payroll@hr-portal-
            update.example.net",
  "subject": "【緊急】薪資帳戶驗證通知",
  "url": "hxxps://hr-portal-update
        [.]example[.]net/login",
  "src_ip": "203.0.113.45",
  "attachment_sha256": "a3f5c9...d41e",
  "recipient_count": 47
}
```

同一時間...

- EDR 又丟出 3 條相關告警，欄位名稱、格式完全不同
- Threat Intel 對這個網域也有一筆記錄
- 以前：L1 開五個視窗人工拼湊
- 現在：Stage 1 全部收斂成一份 OCSF Normalized Alert

 5 條雜亂告警 +  OCSF → Uh! 1 份 Normalized Alert !

實戰走一遍 (2/3)：系統查了什麼？

Step 2 — RAG 檢索 + Prompt 組裝

Knowledge Base 撈回來的東西

- SOP-PH-001 釣魚信處理程序 (相似度 0.92)
- Ticket #4471：上季同類 campaign 的完整處置紀錄 (0.88)
- Wiki：郵件闖道封鎖申請流程 (0.85)

組裝後的 Prompt 結構

- System instructions：輸出格式 + 防護欄
- Normalized Alert (Step 1 的產出)
- 檢索到的 SOP + 歷史案例
- 任務：產出三層 deliverables

Normalized Alert + 撈回來的知識 → Uh! Context-Aware Prompt !

實戰走一遍 (3/3) : AI 起草，人類拍板

Step 3 — 90 秒草稿 vs. 分析師修正

AI 草稿 (90 秒內)

- 判定：釣魚 campaign，信心高
- 封鎖寄件網域與 URL
- 隔離 47 封已投遞郵件
- 通知 47 位收件者強制改密碼

分析師修正

- 確認判定 ✓ 封鎖動作 ✓
- 補充：EDR 顯示其中 3 位已點擊連結 → 升級為事件處理
- 改密碼範圍縮小到 3 位點擊者，其餘改為全員資安公告
- 按下 Approve → 修正寫回 Knowledge Base

 草稿 +  修正拍板 → Uh! 回饋進 KB，下一次更準！

先講清楚：這裡會炸

Known failure modes — POC 階段就要驗的東西

幻覺 IOC

AI 可能自信地「捏造」IP、hash 或網域。

防線：輸出中每個 IOC 必須可回溯到原始告警 (citation check)，對不上就擋下。

Prompt Injection

攻擊者可以把「給 AI 的指令」寫進釣魚信內文，順著告警流進 prompt。

防線：告警內容一律視為資料而非指令，輸入隔離 + 輸出過濾。

知識庫過期

舊 SOP 會讓 AI 很有自信地給出過時建議。

防線：KB 版本控管、來源標註日期、定期 re-embedding。

橡皮圖章效應

人類審久了會無腦按 Approve，HITL 名存實亡。

防線：抽樣稽核 + 低信心分數強制深審，採納率列入 POC 指標。

Key Takeaways

- AI 跟 SOC 都不是新東西 — 合體的方式才是重點
- RAG + Human-in-the-Loop = 準確、可稽核、持續進化
- AI-SOC 不是取代分析師，是讓分析師升級

DevSecOps Taiwan



https://bit.ly/AG3_DevSecOps